

Threat Model

OpenMRS LegacyUI Module — IN-B2.4 Security

Project	IN-B2.4 Security — Avans Hogeschool HBO-ICT
Module	legacyui-audit (OpenMRS Platform 2.0.0 + LegacyUI)
Datum	2026-06-05
Methodiek	STRIDE (NEN-7510:2024-2 bijlage B)
Norm	NEN-7510:2024-2 maatregel 8.25 (Veilige ontwikkeling)
Invoer voor	Risicomatrix (WS03) en bow-tie diagrammen (WS04)

Dit document beschrijft het dreigingsmodel voor de OpenMRS LegacyUI-module op basis van broncode-analyse. De STRIDE-methode is toegepast conform NEN-7510:2024-2 bijlage B. Alle dreigingen zijn voorzien van numerieke risicoscores (kans × impact, schaal 1–5) en dienen als directe invoer voor de risicomatrix (WS03) en bow-tie diagrammen (WS04).

1. Aanvalsvlak-overzicht (Attack Surface)

1.1 Externe invoerkanalen

Invoerkanaal	Locatie	Opmerking
HTTP-formulievelden	150+ JSP-bestanden (omod/src/main/webapp/)	Naam, BSN, wachtwoord, medische gegevens
Bestandsuploads	moduleList.jsp, obsForm.jsp, addFormResource.jsp	.omod modules, obs-bijlagen, formulierresources
Query-parameters (GET)	q/locationHierarchy, q/message, patientDashboard.form	Zoekterms, patiënt-ID's
DWR/AJAX-parameters	/dwr/*, /ms/call/plaincall/*	JSON-berichten via JavaScript-RPC (16 serviceklassen)
Omgevingsvariabelen	docker-compose.yml, .env	DB-wachtwoorden, systeemconfiguratie
HL7-berichten	/admin/hl7/* controllers	Medische berichten van externe systemen (BSN, diagnoses)

1.2 Hoog-risico eindpunten samengevat

Risico	Eindpunt	Privilege	Invoervalidatie	Autorisatie	Voornaamste dreiging
■	/forgotPasswordForm	Geen (publiek)	Minimaal	Nee	Account-overname via geheime vraag
■	/admin/modules/manage/	MANAGE_MODULES	Geen type-validatie	Ja	RCE via kwaadaardig .omod
■	/admin/users/user.form	EDIT_USERS	Beperkt	Ja — geen CSRF	Privilegeverhoging, CSRF
■	/patientDashboard.form	Authenticatie	Nee	isAuthenticated() — geen GET_PATIENTS	BSN/dossier-exposure
■	/dwr/* (16 services)	Authenticatie	Geen per methode	Sessie — geen method-level	CSRF, BSN-lek, XSS
■	/admin/maintenance/systemInfo.htm	Authenticatie	N.v.t.	isAuthenticated()	Versiegegevens-lek

2. Vertrouwensmodel (Trust Boundaries)

Het systeem kent drie vertrouwensgrenzen. Elke grensovergang is een potentieel aanvalspunt.

#	Grens	Aanwezige controles	Ontbrekende controles	NEN-7510
VG 1	Internet ↔ Nginx	TLS verplicht · /openmrs/admin/ geblokkeerd extern · Rate-limiting vereist	■ Rate-limiting niet geconfigureerd	8.20, 8.21
VG 2	Nginx ↔ OpenMRS-applicatie	HTTP intern (Docker) · Sessie-validatie per verzoek via OpenMRS Context	■ CSRF ontbreekt op alle POST-eindpunten (G1)	8.25
VG 3	OpenMRS Core ↔ MySQL	JDBC intern Docker-netwerk · Poort 3306 nooit extern · Credentials via .env	■ Data-at-rest encryptie niet bevestigd	5.33, 8.24

Kritieke keten 1 (DWR): Internet → Nginx → DwrFilter → OpenmrsDWRServlet → [16 DWR-services] → OpenMRS Core → MySQL

Geen CSRF-token, geen method-level autorisatie op elke stap na VG1 (NEN 8.25 gap G1/G4)

Kritieke keten 2 (RCE): Internet → Nginx → ModuleManagementController → ModuleFactory.loadModule() → JVM-executie

Geen bestandstype-validatie → potentieel RCE (NEN 8.8, 8.25 gap G3)

3. STRIDE Dreigingsidentificatie

Risicoscore = Kans (1–5) × Impact (1–5). Kleurcodering: ■ Rood ≥ 16 ■ Oranje 10–15 ■ Geel < 10

S — Spoofing

S1 Brute-force aanval op inlogpagina		Risicoscore: 16
Component	/login (LoginController)	
Beschrijving	Geen rate-limiting, account-lockout of CAPTCHA. Aanvaller kan geautomatiseerd wachtwoorden uitproberen zonder geblokkeerd te worden.	
Bewijs	LoginController.java — geen vertraging, geen lockout-logica aangetroffen in broncode	
Kans	4 (Hoog)	
Impact	4 (Hoog)	
NEN-7510:2024-2	8.5 (Veilige authenticatie), 8.25 (Veilige ontwikkeling)	

S2 Session hijacking via onversleutelde verbinding		Risicoscore: 15
Component	Nginx reverse proxy, OpenMRS sessiemanagement	
Beschrijving	Docker-compose stelt poorten 8081/8082/8083 bloot op HTTP. Geen HTTPS-redirect aanwezig. Sessie-tokens onderschepbaar via MITM.	
Bewijs	docker-compose.yml: HTTP-poorten blootgesteld; geen HTTPS-redirect in Nginx-config	
Kans	3 (Midden)	
Impact	5 (Kritiek)	
NEN-7510:2024-2	8.24 (Gebruik van cryptografie), 8.20 (Netwerkbeveiliging)	

S3 Account-overname via geheime vraag (wachtwoordherstel)		Risicoscore: 12
Component	/forgotPasswordForm (ForgotPasswordFormController)	
Beschrijving	Wachtwoordherstel via geheime vraag is gevoelig voor social engineering en woordenboek-aanvallen. Geen tijdsbeperking op pogingen.	
Bewijs	forgotPasswordForm.jsp: velden secretQuestion en secretAnswer; geen rate-limiting aanwezig	
Kans	3 (Midden)	
Impact	4 (Hoog)	
NEN-7510:2024-2	8.5 (Veilige authenticatie)	

T — Tampering

T1 Cross-Site Request Forgery (CSRF) op alle POST-eindpunten		Risicoscore: 16
Component	Alle POST-eindpunten: user.form, settings.form, modules/manage, obs.form	
Beschrijving	Geen CSRF-tokens in JSP-formulieren of Spring-configuratie. Een aanvaller kan via een kwaadaardige website een geauthenticeerde gebruiker POST-verzoeken laten sturen.	
Bewijs	userForm.jsp, changePasswordForm.jsp, login.jsp — geen ; geen Spring Security CSRF-filter in config.xml	
Kans	4 (Hoog)	
Impact	4 (Hoog)	
NEN-7510:2024-2	8.25 (Veilige ontwikkeling — sessiebeveiliging)	

T2 Remote Code Execution via kwaadaardige .omod-uploadRisicoscore: 10	
Component	/admin/modules/manage/ (ModuleManagementController, moduleList.jsp)
Beschrijving	Geen bestandstype-validatie aanwezig. Een kwaadaardig .omod-bestand wordt als Java-code uitgevoerd in de JVM, wat leidt tot volledige servercompromittering.
Bewijs	moduleList.jsp r.151: multipart upload zonder type-validatie; geen MIME-check aangetroffen
Kans	2 (Laag)
Impact	5 (Kritiek)
NEN-7510:2024-2	8.25 (Veilige ontwikkeling), 8.8 (Technische kwetsbaarheden)

T3 Cross-Site Scripting (XSS) via DWR-parametersRisicoscore: 12	
Component	/dwr/*, /ms/call/plaincall/* (16 DWR-serviceklassen)
Beschrijving	XSSFilter dekt reguliere HTTP-verzoeken maar DWR gebruikt eigen request-dispatching. Niet aantoonbaar dat XSSRequestWrapper ook DWR-parameters filtert.
Bewijs	XSSFilter.java wraps non-GET; DwrFilter.java routeert /dwr/* intern — filterchain-dekking onbevestigd
Kans	3 (Midden)
Impact	4 (Hoog)
NEN-7510:2024-2	8.25 (Output-encoding, inputvalidatie)

R — Repudiation

R1 Ontbrekende auditlogging voor beveiligingsgebeurtenissenRisicoscore: 20	
Component	Alle controllers, DWR-services, ForcePasswordChangeFilter
Beschrijving	Geen expliciete auditlogging voor kritische handelingen: inlogpogingen, wachtwoordwijzigingen, gebruikersaanmaken, module-uploads. "Niet gelogd = niet gebeurd."
Bewijs	LoginController, ChangePasswordFormController, UserFormController, ModuleManagementController — geen security-event logging aangetroffen
Kans	5 (Hoog — structureel ontbrekend)
Impact	4 (Hoog)
NEN-7510:2024-2	8.16 (Monitoringactiviteiten), 5.33 (Bescherming van registraties)

I — Information Disclosure

I1 Versiegegevens bereikbaar via systeeminformatiepaginaRisicoscore: 12	
Component	/admin/maintenance/systemInfo.htm (SystemInformationController)
Beschrijving	Versie nummers van OpenMRS-componenten, Java-versie en serverinformatie zichtbaar voor alle geauthenticeerde gebruikers. Vereenvoudigt gerichte CVE-exploitatie.
Bewijs	SystemInformationController — versiedetails zonder specifieke privilege-check voor rol
Kans	4 (Hoog)
Impact	3 (Midden)
NEN-7510:2024-2	8.8 (Beheer van technische kwetsbaarheden)

I2 Patiëntgegevens en BSN blootgesteld via DWR AJAX		Risicoscore: 15
Component	/dwr/* — DWRPatientService, DWRPersonService, DWRObsService	
Beschrijving	Zonder method-level autorisatie kan elke geauthenticeerde gebruiker alle patiënten opvragen, ongeacht GET_PATIENTS-privilege.	
Bewijs	config.xml r.69-82: findPatients, getPatient, getSimilarPatients in allowlist; geen per-method privilege-check	
Kans	3 (Midden)	
Impact	5 (Kritiek)	
NEN-7510:2024-2	8.2 (Bevoorrechte toegangsrechten), 8.25 (Autorisatiecontrole)	

I3 HL7-berichten bevatten onversleutelde medische gegevens		Risicoscore: 8
Component	/admin/hl7/* (HI7InQueueListController, HI7InArchiveListController)	
Beschrijving	HL7-berichten in wachtrij en foutarchief bevatten medische patiëntgegevens. Toegang vereist slechts basisauthenticatie, niet een specifiek HL7-privilege.	
Bewijs	HI7InQueueListController — geen specifiek HL7-privilege aantoonbaar	
Kans	2 (Laag)	
Impact	4 (Hoog)	
NEN-7510:2024-2	8.24 (Gebruik van cryptografie), 5.33 (Bescherming van registraties)	

D — Denial of Service

D1 Geen rate-limiting op authenticatie-eindpunten		Risicoscore: 16
Component	/login (LoginController), /forgotPasswordForm	
Beschrijving	Geen account-lockout of tijdelijke blokkering bij herhaalde mislukte pogingen. Maakt brute-force én opzettelijke account-lockout DoS mogelijk (artsen buitengesloten).	
Bewijs	LoginController — geen lockout-mechanisme aangetroffen	
Kans	4 (Hoog)	
Impact	4 (Hoog)	
NEN-7510:2024-2	8.5 (Veilige authenticatie), 8.25 (Veilige ontwikkeling)	

D2 Onbeperkte bestandsupload-grootte		Risicoscore: 6
Component	/admin/modules/manage/, /admin/observations/obs.form, /admin/forms/addFormResource	
Beschrijving	Geen maximale bestandsgrootte aanwezig. Aanvaller met uploadprivilege kan serveropslag en geheugen uitputten.	
Bewijs	moduleList.jsp: multipart-formulier zonder size-restrictie; geen MaxUploadSizeExceededException-handler aangetroffen	
Kans	2 (Laag)	
Impact	3 (Midden)	
NEN-7510:2024-2	8.25 (Inputvalidatie — invoergrootte)	

E — Elevation of Privilege

E1 Aanmaken beheerdersaccount via UserFormController		Risicoscore: 15
Component	/admin/users/user.form (UserFormController)	
Beschrijving	Bij succesvolle CSRF-aanval of gecompromitteerd EDIT_USERS-account kan aanvaller een nieuw beheerdersaccount aanmaken of bestaande rollen escaleren.	
Bewijs	UserFormController r.200-227: role-assignment via formulier; EDIT_USERS-check aanwezig maar geen CSRF-beveiliging	
Kans	3 (Midden)	
Impact	5 (Kritiek)	
NEN-7510:2024-2	8.2 (Bevoorrechte toegangsrechten), 8.25 (Autorisatiecontrole)	

E2 Volledig systeemcompromis via .omod RCE (gecombineerd met T1/S1)		Risicoscore: 10
Component	/admin/modules/manage/ (ModuleManagementController)	
Beschrijving	Via CSRF (T1) of brute-force (S1) gevolgd door kwaadaardige .omod-upload geeft aanvaller volledige controle over server, database en alle patiëntgegevens.	
Bewijs	moduleList.jsp r.151-155: upload actief zonder validatie; ModuleFactory.loadModule() voert Java-code uit	
Kans	2 (Laag)	
Impact	5 (Kritiek)	
NEN-7510:2024-2	8.25 (Veilige ontwikkeling), 8.8 (Technische kwetsbaarheden), 8.2 (Bevoorrechte toegang)	

4. NEN-7510:2024-2 Maatregel 8.25 — Gap-analyse

Maatregel 8.25 vereist: inputvalidatie op type/formaat/lengte, autorisatiecontroles, output-encoding, en correcte CSRF-bescherming en sessiemanagement.

#	Gap	Ernst	Aanbevolen maatregel
G1	Geen CSRF-bescherming op alle POST-eindpunten	Kritiek	Implementeer Spring Security CSRF-tokens op alle POST-formulieren
G2	Geen rate-limiting op /login en /forgotPasswordForm	Hoog	Nginx limit_req_zone op authenticatie-eindpunten
G3	Geen bestandstype-validatie bij module-upload	Kritiek	Valideer MIME-type + extensie; overweeg digitale handtekening voor .omod
G4	Geen method-level autorisatie op DWR-services	Hoog	GET_PATIENTS op DWRPatientService.findPatients(); GET_OBS op DWRObsService; GET_USERS op DWRUserService
G5	Geen invoerlengtebeperking op DWR-parameters	Hoog	Voeg maximale lengtevalidatie toe per DWR-methode
G6	Ontbrekende auditlogging voor beveiligingsgebeurtenissen	Hoog	Log inlogpogingen, wachtwoordwijzigingen, module-uploads via OpenMRS Log4j (de 5 W's)
G7	Versiegegevens bereikbaar voor alle gebruikers	Midden	Beperk /admin/maintenance/systemInfo tot specifiek privilege (SYSTEM_DEVELOPER)
G8	Kwetsbaar wachtwoordherstelmechanisme	Midden	Vervang geheime vraag door e-mail/OTP-gebaseerd herstel

5. Dreigingentabel — Invoer voor risicomatrix (WS03) en bow-tie (WS04)

Gesorteerd op risicoscore (hoog → laag). Kans × Impact op 5×5 schaal conform vastgestelde risicobereidheid variant B.

ID	Dreiging	Component	Kans	Impact	Score	Prioriteit	NEN-7510
R1	Ontbrekende auditlogging	Alle controllers	5	4	20	Kritiek	8.16, 5.33
T1	CSRF op alle POST-eindpunten	Alle POST-eindpunten	4	4	16	Kritiek	8.25
S1	Brute-force op inlogpagina	/login	4	4	16	Kritiek	8.5, 8.25
D1	DoS via inlogflooding	/login, /forgotPasswordForm	4	4	16	Kritiek	8.5, 8.25
S2	Session hijacking via HTTP	Nginx, sessiemanagement	3	5	15	Kritiek	8.24, 8.20
I2	BSN-lek via DWR AJAX	/dwr/*, DWRPatientService	3	5	15	Kritiek	8.2, 8.25
E1	Privilegeverhoging via user.form	/admin/users/user.form	3	5	15	Kritiek	8.2, 8.25
S3	Account-overname via geheime vraag	/forgotPasswordForm	3	4	12	Hoog	8.5
T3	XSS via DWR-parameters	/dwr/*	3	4	12	Hoog	8.25
I1	Versiegegevens lek	/admin/maintenance/systemInfo.htm	4	3	12	Hoog	8.8
T2	RCE via .omod-upload	/admin/modules/manage/	2	5	10	Hoog	8.25, 8.8
E2	Systeemcompromis via .omod RCE	/admin/modules/manage/	2	5	10	Hoog	8.2, 8.8, 8.25
I3	HL7-gegevens onvoldoende afgeschermd	/admin/hl7/*	2	4	8	Midden	8.24, 5.33
D2	Opslag-uitputting via upload	Uploadpunten	2	3	6	Midden	8.25

Gebruik van deze tabel: Kopieer de ID-kolom (S1–E2) en risicoscores direct naar de risicomatrix (WS03). De drie hoogste risico's (R1=20, T1=16, S1=16, D1=16) zijn de primaire kandidaten voor bow-tie analyse (WS04). Alle maatregelen zijn gekoppeld aan NEN-7510:2024-2 voor het auditrapport (WS06).